



INSTITUTO POLITÉCNICO NACIONAL
ESCUELA SUPERIOR DE CÓMPUTO



Sesión de Laboratorio 9:

CERTIFICADOS DIGITALES



SELECTED TOPICS OF CRYPTOGRAPHY

Profesora || **Sandra Díaz Santiago**
Grupo || **7CM1**
Alumno || **Areli Alejandra Guevara Badillo**

15 de mayo de 2026

PREGUNTAS

Lee el estándar **NIST SP1800-16** para responder a las siguientes preguntas:

1. ¿Qué hace una autoridad de certificación (CA)?

Una Autoridad de Certificación (CA) es una entidad de confianza (ya sea interna de la organización o pública externa) encargada de emitir y gestionar certificados digitales. Su función principal es validar la identidad de un sujeto (como un servidor, dispositivo o usuario) y vincular de forma criptográfica esa identidad con su respectiva clave pública, firmando digitalmente el certificado para garantizar su autenticidad.

2. ¿Cuáles son los tres tipos diferentes de certificados emitidos por una CA pública?

Las CA públicas emiten tres tipos principales de certificados TLS, dependiendo del nivel de verificación de identidad que realizan:

- ▶ **Validación de Dominio (DV - Domain Validated):** El nivel más básico, donde la CA solo verifica que el solicitante tiene el control técnico sobre el dominio de internet.
- ▶ **Validación de Organización (OV - Organization Validated):** Además de comprobar el control del dominio, la CA verifica información básica sobre la organización comercial o entidad que solicita el certificado.
- ▶ **Validación Extendida (EV - Extended Validation):** Requiere un proceso de verificación de identidad mucho más riguroso, exhaustivo y estandarizado para validar legalmente a la organización.

3. ¿Cuáles son los pasos que sigue un administrador de sistemas para obtener un certificado TLS para un servidor que gestiona?

El ciclo de vida descrito en el volumen del estándar detalla los siguientes pasos operativos:

1. **Generación de claves:** El administrador genera un par de claves criptográficas (pública y privada) localmente en el servidor.
2. **Creación del CSR:** Se genera una Solicitud de Firma de Certificado (Certificate Signing Request), un archivo estructurado que contiene la clave pública recién creada y los datos de identidad del servidor.
3. **Envío a CA:** El administrador transmite el CSR a la CA seleccionada a través de sus portales o APIs.
4. **Validación y Emisión:** La CA ejecuta el proceso de validación correspondiente al tipo de certificado solicitado (DV, OV o EV) y, tras verificarlo, firma y emite el certificado.
5. **Instalación:** El administrador descarga el certificado emitido y lo configura en el servidor web junto con la clave privada y los certificados intermedios (cadena de confianza).

4. ¿Qué es una interrupción del servicio (application outage)? Enumera cinco escenarios que puedan causar una interrupción.

Una interrupción del servicio (*application outage*) ocurre cuando una aplicación o servicio web deja de estar disponible para los usuarios. En el contexto de TLS, esto suele suceder debido al vencimiento de un certificado TLS o a retrasos en el reemplazo de certificados y claves privadas.

Cinco escenarios comunes que causan esta interrupción por certificados son:

1. **Expiración inadvertida:** El certificado cumple su fecha de vigencia porque nadie monitoreaba su ciclo de vida.
2. **Alertas ignoradas:** El sistema emitió notificaciones automáticas previas al vencimiento, pero los administradores las pasaron por alto o las consideraron spam.
3. **Rotación de personal (Key person dependency):** El empleado que configuró originalmente el certificado o recibía los correos de renovación dejó la empresa y nadie más heredó la responsabilidad.
4. **Despliegue incompleto:** El certificado se renovó y pagó a la CA, pero el administrador olvidó realizar la instalación física o reiniciar el servicio web para aplicar los cambios.
5. **Sistemas fuera de sincronía:** En arquitecturas con balanceadores de carga o clústeres de servidores, el certificado se actualizó en algunos nodos, pero no en todos, provocando caídas intermitentes.

5. ¿Cuáles son los posibles riesgos de los certificados de servidor TLS? Explica dos de ellos con tus propias palabras

Los riesgos documentados relacionados con la gestión de certificados TLS incluyen:

- Interrupciones de aplicaciones (Outages) por certificados expirados.
- Suplantación de servidor (Server Impersonation) por compromiso de claves.
- Amenazas cifradas (Encrypted Threats) que ocultan intrusiones o robo de datos.
- Falta de Cripto-agilidad (Lack of Crypto-Agility) ante vulnerabilidades de algoritmos.

Explicación de dos riesgos:

- **Interrupciones por certificados expirados:** Cuando no se renueva un certificado a tiempo, los navegadores marcan el sitio web como "No seguro" y bloquean la conexión de los usuarios. Esto significa que la plataforma se vuelve inaccesible, lo cual detiene las operaciones del negocio y genera pérdidas económicas y de confianza.
- **Suplantación de servidor:** Si la clave privada de un servidor no se guarda bien y un cibercriminal la roba, este puede levantar un servidor "clon" que se haga pasar por el original. Para los usuarios, el candado de seguridad aparecerá como válido, por lo que introducirán sus contraseñas o datos bancarios creyendo que están en el sitio real, entregándoselos directamente al atacante.